

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	This app will connect the shoppers to sellers and will be handling transactions. It will be handling PII and have several payment options. It will have multiple backend processing such as logging in, sales transactions, direct contact with messaging sellers etc. The card transactions regulations will need to be included/considered.
II. Define the technical scope	List of technologies used by the application: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> The PKI's and then the SQL database should take priority when being protected. The PKI directly handles securing sensitive information. Prioritizing credit card sensitive data is key. Also securing the database where all this information is being sent is also a priority.
III. Decompose application	Sample data flow diagram
IV. Threat analysis	Two potential threats for this app are SQL injection and session hijacking. Because user credentials are involved SQL injection may be a risk and session hijacking can be a possibility if users are not careful with login credentials.
V. Vulnerability analysis	Weak passwords can be exploited since users may not take password policies seriously. There could also be a lack of prepared statements.
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	Security controls that can be implemented are: Prepared statements and data sanitization, threat modeling to identify assets and vulnerabilities to ensure protecting the entire attack

	surface and implementing strict password policies.
--	--

Threat Modeling for a Sneaker Marketplace Application

Overview

This assignment focuses on applying threat modeling principles to a hypothetical sneaker marketplace application. The goal was to understand how business objectives, technical scope, and application architecture influence security risks, and how to identify and mitigate those risks early in the design process.

I. Business and Security Objectives

The application is designed to connect sneaker buyers with sellers while facilitating secure transactions. It handles sensitive information including personally identifiable information (PII) and payment card data, and supports multiple backend processes such as user authentication, transaction processing, and direct messaging between users.

Because financial transactions are involved, compliance with card payment regulations is a key security consideration. Protecting user trust, ensuring data confidentiality, and maintaining system availability are core security objectives.

II. Technical Scope

The application relies on the following technologies:

- Application Programming Interfaces (API)
- Public Key Infrastructure (PKI)
- SHA-256 hashing

- SQL database

From a security perspective, PKI and the SQL database are the highest-priority assets. PKI is responsible for securing sensitive data in transit, while the database stores critical information such as user credentials and payment-related data. Protecting these components is essential to reducing overall risk.

III. Application Decomposition

The application can be broken down into several functional components:

- User authentication and login
- Product listings and sales transactions
- Payment processing
- Messaging between buyers and sellers
- Backend data storage and logging

A data flow diagram would illustrate how data moves between users, APIs, backend services, and the database, helping identify trust boundaries and potential attack surfaces.

IV. Threat Analysis

Two primary threats were identified:

- **SQL Injection**
Since user input is accepted and processed by the database, improper input handling could allow attackers to manipulate SQL queries and access sensitive data.
 - **Session Hijacking**
If sessions are not properly managed or protected, attackers could take over active user sessions, gaining unauthorized access to accounts and transactions.
-

V. Vulnerability Analysis

Potential vulnerabilities include:

- Weak password practices, which can make accounts easier to compromise
- Lack of prepared statements, increasing susceptibility to SQL injection attacks

These vulnerabilities highlight the importance of both secure coding practices and user-focused security controls.

VI. Attack Modeling

An attack tree model can be used to visualize how an attacker might exploit vulnerabilities, such as leveraging weak credentials or injecting malicious SQL queries to access protected data. This helps clarify possible attack paths and points of failure within the system.

VII. Risk Analysis and Impact

To reduce risk and limit potential impact, the following security controls are recommended:

- Use prepared statements and input sanitization to prevent SQL injection
 - Implement strong password policies to reduce credential-based attacks
 - Apply threat modeling consistently to identify assets, vulnerabilities, and attack surfaces early
 - Protect sensitive data using encryption and secure key management
-

Key Takeaway

This exercise reinforced that security is not just about tools, but about understanding how business goals, technical design, and human behavior intersect. Threat modeling provides a

structured way to think through risks before they become incidents, and helps prioritize controls where they matter most.